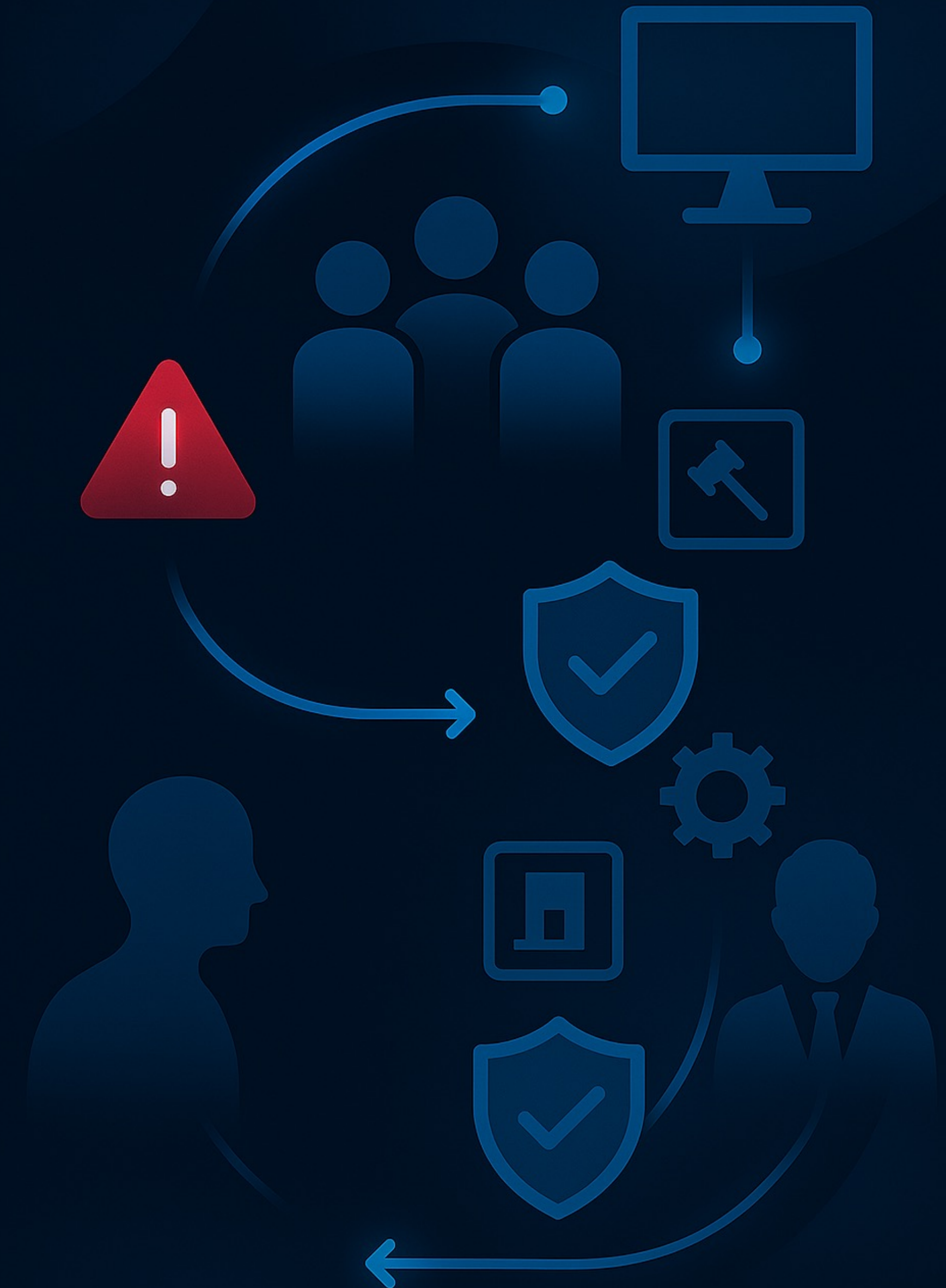


Cybersecurity Kommunikation (CYSECO)

Effektives Melden von
Schwachstellen

Information Technology
October 22, 2025



Lernziele

Die Teilnehmenden können

- Die Begriffe und Grundprinzipien verstehen
- Die Einbettung dieser Prinzipien in ihr Unternehmen verstehen und erklären
- Die wesentlichen regulatorischen Anforderungen verstehen und umsetzen
- Die Prozesse und Akteure erklären
- Die entsprechenden Kommunikationsanforderungen verstehen
- Ein «Vulnerability Disclosure Advisory» (VDA) erstellen

Welche Regelwerke sind wesentlich?

Netzwerk- und Informationssicherheit (NIS) 2

Fokus auf Organisationen und Dienste

Adressaten: Unternehmen und Organisationen, die wesentliche oder wichtige Dienstleistungen erbringen (z. B. Energie, Gesundheit, Transport, digitale Infrastruktur).

Ziel: Stärkung der Cybersicherheit auf organisatorischer Ebene durch verpflichtende Risikomanagement-Maßnahmen, Meldepflichten für Sicherheitsvorfälle und Zusammenarbeit zwischen den EU-Mitgliedstaaten.

Pflichten: Einführung und Nachweis von Cybersicherheitsmaßnahmen, Vorfallmanagement, Nutzung zertifizierter Produkte kann verlangt werden.

Cyber Resilience Act (CRA)

Fokus auf Produkte

Adressaten: Hersteller, Importeure und Händler von Produkten mit digitalen Elementen (Hardware & Software, z. B. IoT-Geräte, Betriebssysteme, Cloud-Dienste).

Ziel: Cybersicherheit „by Design“ – Produkte müssen bereits bei der Entwicklung und während des gesamten Lebenszyklus Sicherheitsanforderungen erfüllen.

Pflichten: Sicherheitsupdates, Schwachstellenmanagement, verpflichtende CE-Kennzeichnung für digitale Produkte, Konformitätsbewertung und ggf. Zertifizierung nach dem Cybersecurity Act .

Zusammenhang NIS2 <-> CRA

Ergänzende Wirkung:

- **NIS2** sorgt dafür, dass Unternehmen und Organisationen ihre IT-Infrastruktur und Prozesse absichern.
- **CRA** stellt sicher, dass die eingesetzten digitalen Produkte selbst sicher sind und bleibt während ihres gesamten Lebenszyklus sicher.

Gemeinsames Ziel: Beide Regelwerke erhöhen das allgemeine Cybersicherheitsniveau in der EU – NIS2 auf der Ebene der Organisationen und kritischen Dienste, CRA auf der Ebene der Produkte.

Verzahnung: NIS2 kann die Nutzung zertifizierter Produkte (z. B. nach CRA und Cybersecurity Act) vorschreiben. Umgekehrt profitieren Unternehmen, die NIS2 umsetzen, von sicheren Produkten gemäß CRA

Von was sprechen wir genau? Was muss gemeldet werden?

Schwachstellen

Definition:

- Schwachstellen sind Sicherheitslücken oder Fehler in IT-Systemen, Software oder Prozessen, die potenziell von Angreifern ausgenutzt werden können
- Beispiele: ungepatchte Software, Standardpasswörter, offene Ports.

Regulatorische Anforderungen:

- **NIS2:** Unternehmen müssen Schwachstellen aktiv managen, aber eine **direkte Meldepflicht für alle Schwachstellen besteht nicht**. Die Meldepflicht greift erst, wenn eine Schwachstelle tatsächlich zu einem erheblichen Sicherheitsvorfall führt.
- **CRA:** Hersteller, Importeure und Händler von Produkten mit digitalen Elementen müssen aktiv ausgenutzte Schwachstellen (also Schwachstellen, die bereits für einen Angriff genutzt wurden) **innerhalb von 24 Stunden an Behörden und ENISA melden**. Zusätzlich sind Prozesse für das Schwachstellenmanagement und die koordinierte Offenlegung vorgeschrieben.

Vorfälle

Definition:

Ein Sicherheitsvorfall ist ein tatsächliches Ereignis, bei dem die Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen oder Systemen beeinträchtigt wurde – z. B. durch einen erfolgreichen Angriff, Datenverlust, Systemausfall oder Sabotage.

Regulatorische Anforderungen:

- **NIS2:** Es besteht eine Meldepflicht für erhebliche Sicherheitsvorfälle, die die Erbringung wesentlicher Dienste beeinträchtigen oder zu erheblichen Schäden führen können. Die Meldung muss in der Regel **innerhalb von 24 Stunden nach Kenntniserlangung** erfolgen, mit weiteren Nachmeldungen innerhalb von 72 Stunden und einer Abschlussmeldung nach spätestens einem Monat.
- **CRA:** Auch hier müssen schwerwiegende Sicherheitsvorfälle, die die Sicherheit eines Produkts mit digitalen Elementen betreffen, **innerhalb von 24 Stunden** gemeldet werden.

Lebenszyklus einer Schwachstelle



**Veröffentlichung
(Disclosure)**

Entstehung
(Creation)



Entdeckung
(Discovery)



Patch verfügbar



Post - Disclosure



Angriffsvektor
(Exploit)



Patch
implementiert

Wichtige Begriffe und Normen in diesem Zusammenhang...

Begriff	Bedeutung	Kurzbeschreibung	Beispiel
CVD	Coordinated Vulnerability Disclosure	Abgestimmte Offenlegung von Schwachstellen zwischen Forschern, Herstellern und Vermittlern.	Ein Forscher meldet eine Schwachstelle an den Hersteller, der diese behebt, bevor sie öffentlich gemacht wird.
CVE	Common Vulnerabilities and Exposures	Einzigartige Kennung für öffentlich bekannte Schwachstellen, z. B. CVE-2023-12345.	Die kritische Solarwinds Sicherheitslücke ist z.B. CVE-2025-26399
CVSS	Common Vulnerability Scoring System	System zur Bewertung der Schwere einer Schwachstelle (Skala 0–10).	Obige Schwachstelle hat einen CVSS von 9.8 (kritisch) und erfordert sofortige Maßnahmen.
VDA	Vulnerability Disclosure Advisory	Öffentliche Mitteilung über eine Schwachstelle mit Beschreibung, Bewertung und Maßnahmen.	Hersteller veröffentlicht ein Advisory mit Patch-Informationen und Workarounds.
VDR	Vulnerability Disclosure Report	Interner oder externer Bericht über eine entdeckte Schwachstelle, oft als Basis für ein VDA.	Ein Bericht dokumentiert eine entdeckte Schwachstelle inklusive Analyse und Lösungsvorschlägen.
VDP	Vulnerability Disclosure Policy (or Program)	Programm einer Organisation zur Annahme und Bearbeitung von Schwachstellenmeldungen.	Ein Unternehmen bietet ein Meldeformular für Sicherheitsforscher auf seiner Website an.
ISO 29147	Vulnerability Disclosure Standard	Internationale Norm zur verantwortungsvollen Offenlegung von Schwachstellen.	Die Norm beschreibt, wie Organisationen Schwachstellenmeldungen entgegennehmen und kommunizieren.
ISO 30111	Vulnerability Handling Processes	Norm zur strukturierten Bearbeitung und Behebung gemeldeter Schwachstellen.	Die Norm beschreibt Prozesse zur Analyse und Behebung gemeldeter Schwachstellen.

Typisches Verfahren zur Offenlegung von Sicherheitslücken

1. VDR

- Ein Sicherheitsforscher entdeckt die Schwachstelle in einer Webanwendung, die es erlaubt, sensible Daten über eine unsichere API abzurufen.
- Er erstellt einen VDR, also einen internen Bericht mit:
 - Technischer Beschreibung
 - Reproduzierbarkeit
 - Erste CVSS-Einschätzung
 - Vorschläge zur Behebung

1. CVD

- Der Forscher meldet die Schwachstelle vertraulich an den Hersteller.
- Der Hersteller bestätigt den Befund, beginnt mit der Analyse und Entwicklung eines Patches.
- Beide Parteien stimmen sich über den Zeitplan zur Veröffentlichung ab (z. B. 90 Tage Frist).

3. CVE

- Während der CVD-Phase beantragt der Hersteller oder ein CNA (CVE Numbering Authority) eine CVE-ID.
- Zum Beispiel erhält die Schwachstelle die Kennung CVE-2025-26399, die sie eindeutig identifizierbar macht.

4. CVSS

- CVE-ID: CVE-2025-26399
- Produkt: SolarWinds Web Help Desk
- Komponente: AjaxProxy
- Typ: Deserialisierung nicht vertrauenswürdiger Daten
- Angriffsart: Remote Code Execution (RCE)
- Authentifizierung: Nicht erforderlich
- Angriffsvektor: Netzwerk
- Schweregrad: 9.8 (kritisch) nach CVSS v3.1
 - CVSS-Vektor: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- CWE: CWE-502 – Deserialization of Untrusted Data

5. VDA

- Nach Veröffentlichung des Patches erstellt der Hersteller ein VDA, also eine öffentliche Mitteilung:
- CVE-Nummer: CVE-2025-26399
- Beschreibung der Schwachstelle
- Betroffene Produkte und Versionen
- CVSS-Score: 9.8
- Maßnahmen (z. B. Patch-Link, Workaround)
- Kontakt für Rückfragen

6. VDP – Der gesamte Prozess basiert auf dem **VDP** des Herstellers, das regelt: a) Wie Meldungen entgegengenommen werden, b) Welche Fristen gelten und c) Wie kommuniziert wird. Das VDP ist öffentlich einsehbar und enthält z. B. ein Meldeformular und PGP-Schlüssel.

1. VDR – Vulnerability Disclosure Report

Zweck:

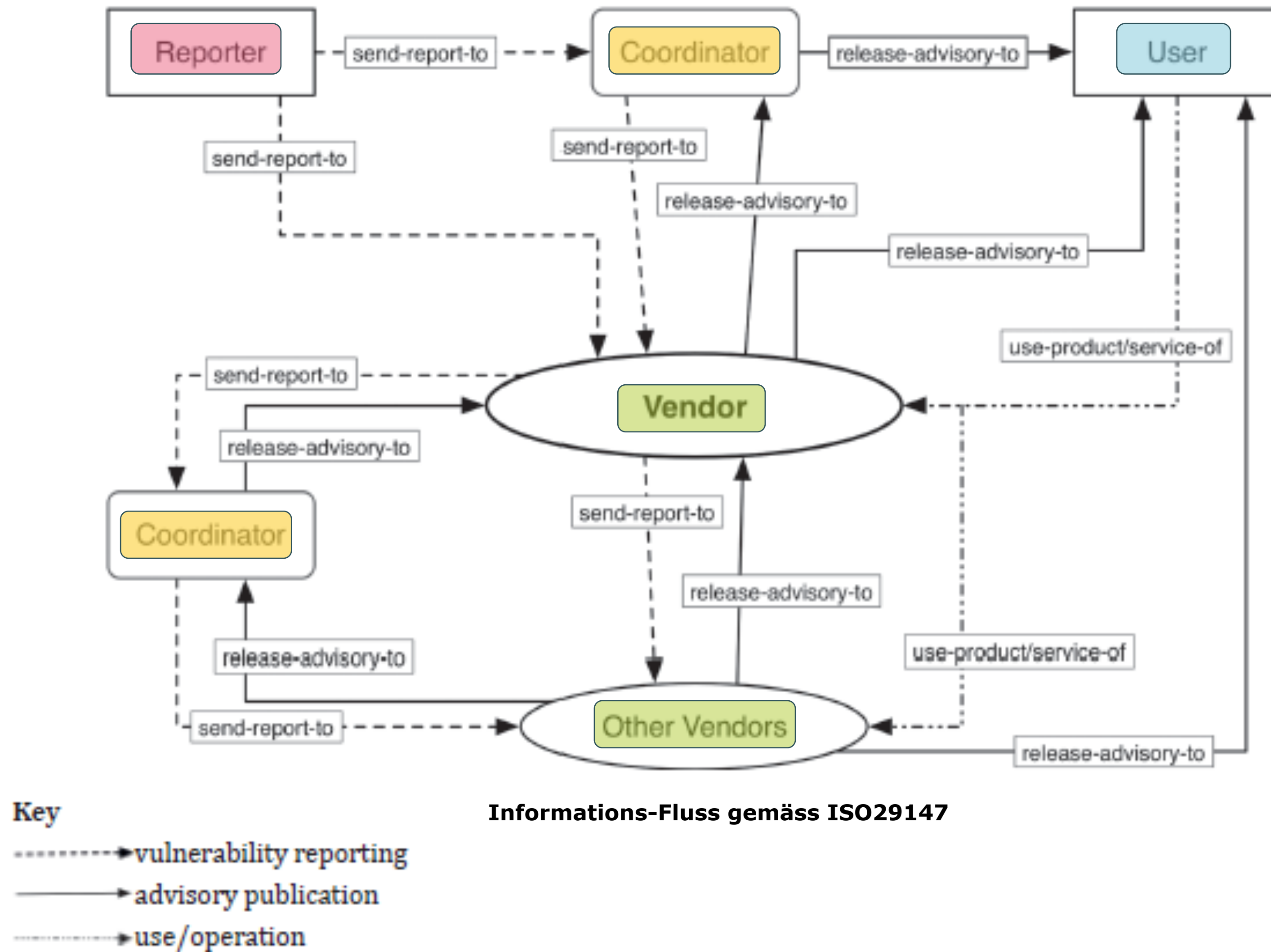
- Dokumentation bekannter und unbekannter Schwachstellen
- Kommunikation gegenüber internen Teams und externen Stakeholdern
- Unterstützung von Bug-Bounty-Programmen, CVD-Prozessen und SBOM*-Analysen

Typische Inhalte:

Abschnitt	Beschreibung
Vulnerability Source	z. B. CVE, interner Fund, Bug-Bounty
Severity Level	z. B. CVSS Score, Kritikalität
Affected Component	z. B. Softwaremodul, Version, Lieferant
Impact Analysis	Technische und betriebliche Auswirkungen
Mitigation Strategy	Patch, Workaround, Konfiguration
Disclosure Status	Offen, in Prüfung, behoben
Timestamp & Signature	Nachvollziehbarkeit und Integrität
Link zur SBOM*	Referenz zur Software-Stückliste (CycloneDX, SPDX etc.)

***SBOM: Software Bill of Materials** – Inventar aller Komponenten, die in einer Software enthalten sind.

2. CVD - Coordinated Vulnerability Disclosure



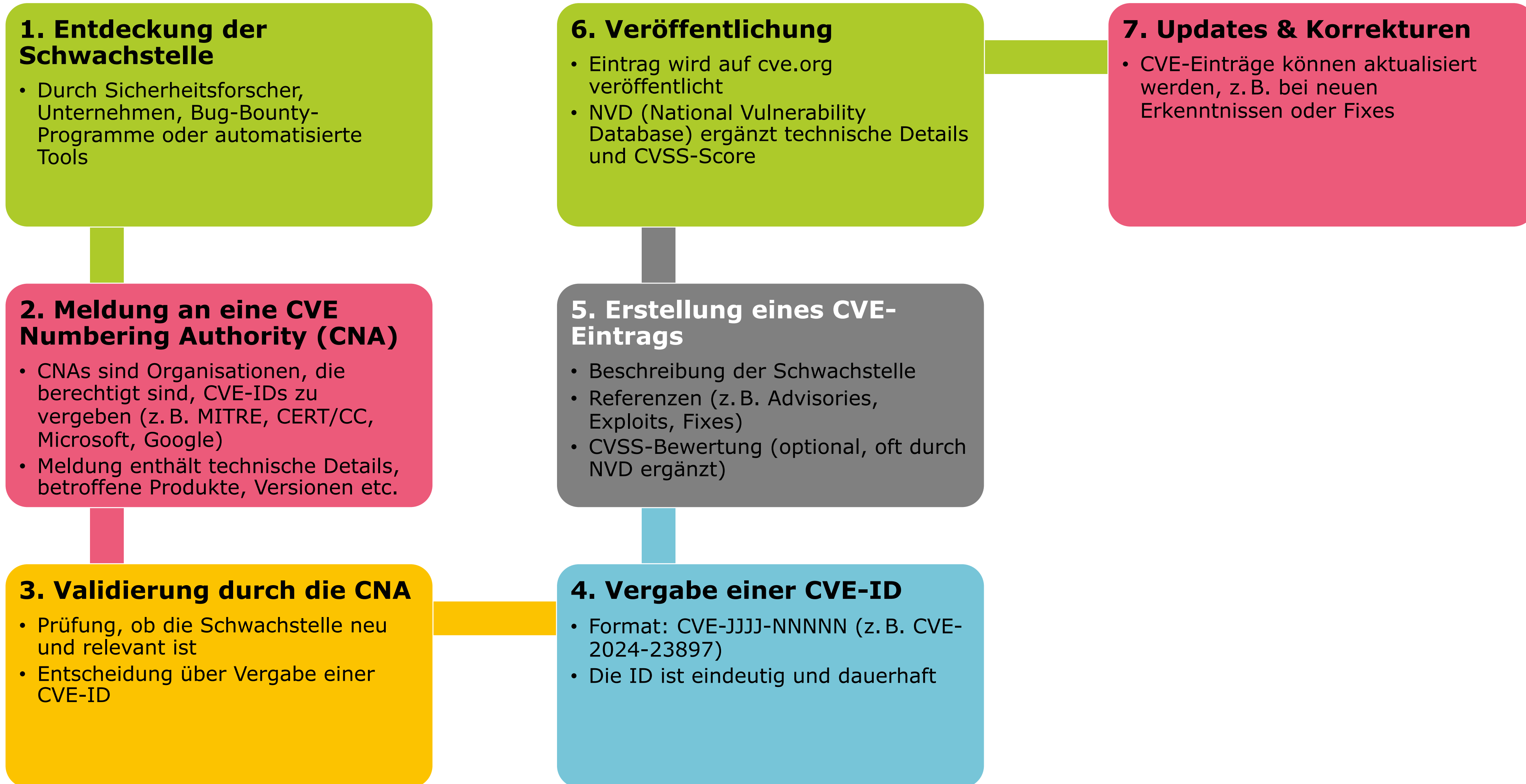
Akteure:

- **Benutzer / User** von Software:
Einzelpersonen, Organisationen oder Regierungen.
- **Hersteller / Vendor** von Software:
Sie sind in der Lage, einen Patch zu veröffentlichen.
- **Entdecker / Reporter** von Schwachstellen:
Gemeinschaft von Einzelpersonen (oder Forschern), die Schwachstellen identifizieren und melden.
- **Koordinatoren / Coordinator:**
Vertrauenswürdige Organisationen (wie Computer Emergency Response Teams (CERT), NCSC), die als Vermittler zwischen Entdeckern und Anbietern fungieren, um sicherzustellen, dass Schwachstellen offengelegt und verantwortungsvoll behandelt werden.

Und:

- **Angreifer / Attacker:**
Personen, die die Schwachstelle ausnutzen, sobald sie offengelegt wurde.

3. CVE – Common Vulnerabilities and Exposures



4. CVSS – Common Vulnerability Scoring System

1. Identifikation der Schwachstelle

- Eine Schwachstelle (z. B. CVE) wird entdeckt und dokumentiert.
- Ziel: Bewertung der potenziellen Auswirkungen und Risiken.

2. Auswahl der CVSS-Metriken

Base Metrics (technische Grundbewertung):

- Attack Vector (**AV**): Lokal, Netzwerk, physisch, etc.
- Attack Complexity (**AC**): Hoch oder niedrig
- Privileges Required (**PR**): Keine, niedrig, hoch
- User Interaction (**UI**): Erforderlich oder nicht
- Scope (**S**): Unverändert oder verändert
- Impact on **CIA**: Jeweils kein, niedrig, hoch

Temporal Metrics: (zeitabhängige Faktoren)

- Exploit Code Maturity: Gibt es funktionierende Exploits?
- Remediation Level: Gibt es einen Patch?
- Report Confidence: Wie verlässlich ist die Quelle?

Environmental Metrics: (kontextabhängig)

- Security Requirements: Wie wichtig sind CIA im jeweiligen Umfeld?
- Modified Base Metrics: Anpassung der Base-Werte an die Umgebung

3. Berechnung des CVSS-Scores

- Der Score liegt zwischen 0.0 (keine Gefahr) und 10.0 (kritisch)
- Tools: CVSS Calculator von FIRST

4. Bewertung des Scores

Score Bereich	Bewertung
0.0	Keine
0.1–3.9	Niedrig
4.0–6.9	Mittel
7.0–8.9	Hoch
9.0–10.0	Kritisch

5. Veröffentlichung

- Der berechnete CVSS-Score wird mit dem CVE-Eintrag veröffentlicht (z. B. über NVD)
- Organisationen nutzen den Score zur Priorisierung von Maßnahmen

5. VDA – Vulnerability Disclosure Advisory

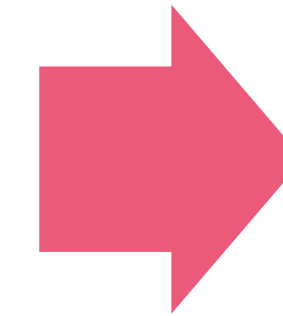
1. Identifikation der Schwachstelle

- Entdeckung durch interne Tests, externe Forscher, Bug-Bounty oder automatisierte Scans



2. Koordinierte Offenlegung (CVD)

- Abstimmung mit Finder, Hersteller und ggf. Behörden
- Ziel: Vermeidung von Zero-Day-Ausnutzung vor Veröffentlichung



3. Erstellung des Advisory-Dokuments

- CVE-ID (falls vorhanden)
- Beschreibung der Schwachstelle
- Betroffene Produkte und Versionen
- CVSS-Score und Bewertung
- Auswirkungen (z. B. RCE, Datenverlust)
- Workarounds, Patches, Updates
- Zeitplan der Offenlegung



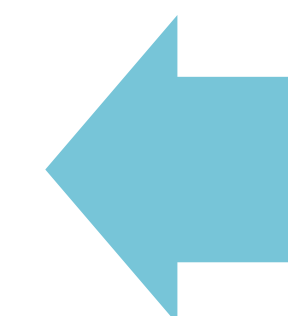
4. Validierung & Freigabe

- Technische Prüfung durch interne Security-Teams oder externe Partner
- Abstimmung mit Kommunikationsabteilung und ggf. Rechtsabteilung



5. Veröffentlichung

- Veröffentlichung auf Website, Mailinglisten, CERT-Portalen, GitHub etc.
- Optional: JSON/CSAF-Format für maschinenlesbare Advisories



6. Nachverfolgung & Updates

- Ergänzungen bei neuen Erkenntnissen, Patch-Status oder Exploit-Verfügbarkeit
- Kommunikation mit Kunden und Partnern

6. VDP – Vulnerability Disclosure Policy

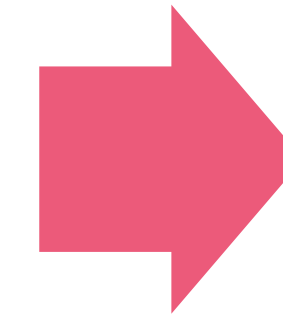
1. Erstellung der Richtlinie

- Ziel und Umfang (z. B. welche Systeme sind betroffen?)
- Kontaktmöglichkeit (z. B. security@domain.tld)
- Erwartungen an den Melder (z. B. keine Ausnutzung, keine Datenweitergabe)
- Verhalten der Organisation (z. B. Reaktionszeit, Anerkennung, ggf. Belohnung)



2. Veröffentlichung

- Auf der Website, z. B. unter /security oder /vulnerability-disclosure-policy
- Optional: Eintrag bei disclose.io oder Bug-Bounty-Plattformen



3. Empfang von Meldungen

- Über E-Mail, Webformular oder Plattform
- Automatische Bestätigung des Eingangs



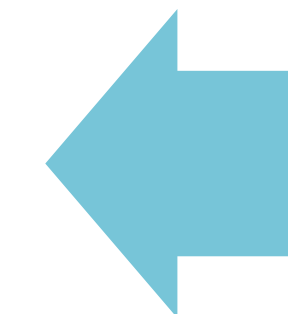
4. Analyse & Bewertung

- Technische Prüfung der gemeldeten Schwachstelle
- Priorisierung nach Kritikalität (z. B. CVSS)



5. Kommunikation mit dem „Finder“

- Rückfragen, Statusupdates, ggf. Koordination der Veröffentlichung (CVD)
- Anerkennung oder Belohnung (optional)



6. Dokumentation & Integration

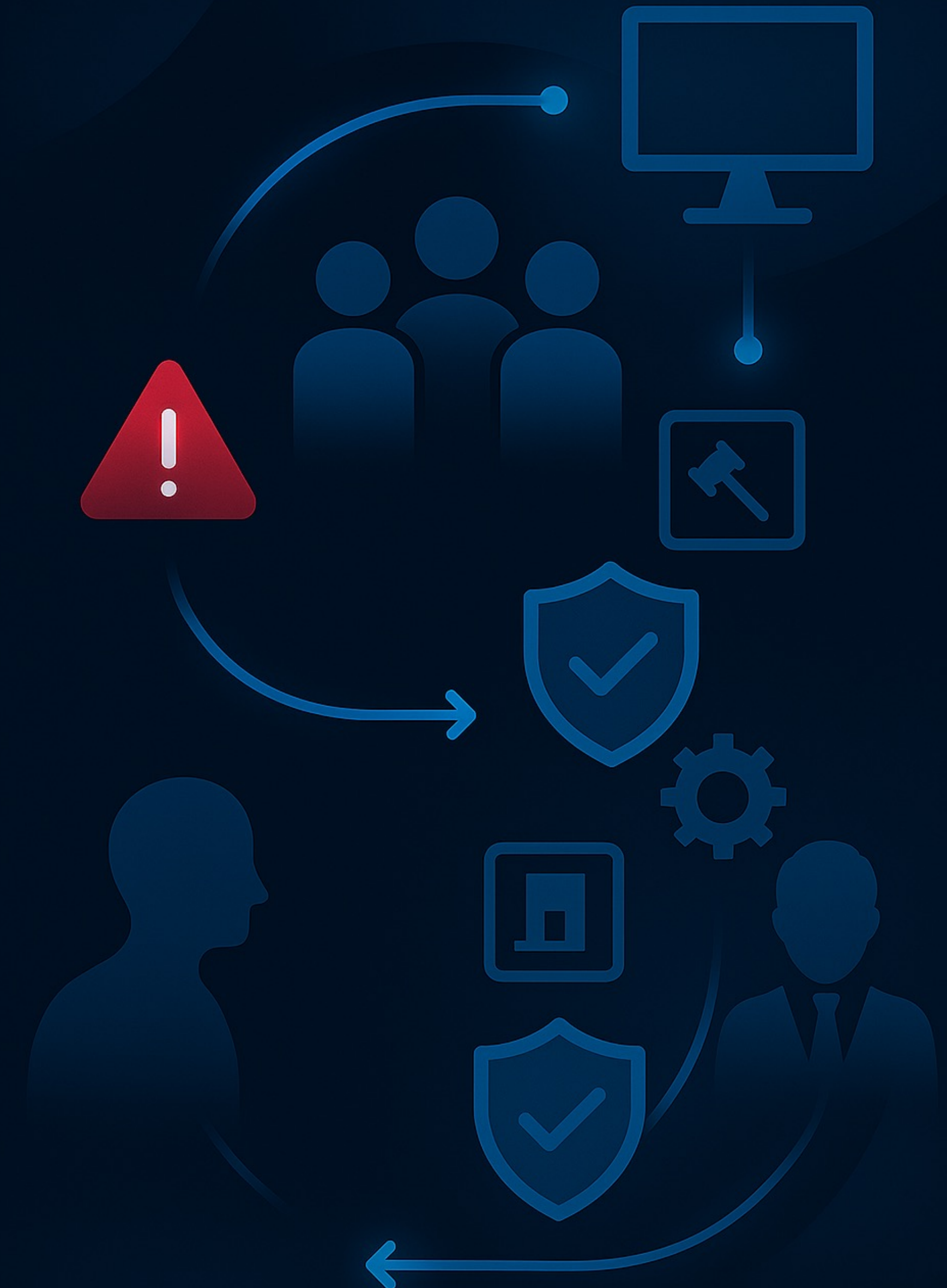
- Eintrag in VDR, CVE-Antrag, Patch-Planung
- Veröffentlichung eines VDA (Advisory), falls relevant

Zuständigkeiten im Überblick

Kürzel	Name	Zuständige Organisation(en)
CVD	Coordinated Vulnerability Disclosure	Hersteller, CERTs, Finder, ggf. Behörden (z. B. ENISA, BSI)
CVE	Common Vulnerabilities and Exposures	MITRE Corporation, CVE Numbering Authorities (CNAs)
CVSS	Common Vulnerability Scoring System	FIRST.org – Forum of Incident Response and Security Teams
VDA	Vulnerability Disclosure Advisory	Hersteller, CERTs, Sicherheitsforscher
VDR	Vulnerability Disclosure Report	Finder, Hersteller, Bug-Bounty-Plattformen, interne Security-Teams
VDP	Vulnerability Disclosure Policy (or Program)	Organisation selbst (z. B. Unternehmen, Behörden, Betreiber kritischer Infrastruktur)
NVD	National Vulnerability Database	NIST oder ENISA für EUVD (European Vulnerability Database)

Beispiel Log4Shell CVE-2021-44228

Information Technology
October 22, 2025



1. VDR – Vulnerability Disclosure Report

Vulnerability Disclosure Report beschreibt die technische Schwachstelle und ihre Auswirkungen.

- **Entdeckt von:** Chen Zhaojun (Alibaba Cloud Security Team)
- **Datum der Meldung an Apache:** 24. November 2021
- **Veröffentlichung:** 10. Dezember 2021
- **Betroffene Versionen:** Log4j 2.0-beta9 bis 2.14.1
- **Technisches Problem:** JNDI Lookup erlaubt Remote Code Execution (RCE) über manipulierte Log-Einträge wie `${jndi:ldap://...}`

Quelle: [Apache Log4j Security Page](#)

CVE-2021-44228

Summary	JNDI lookup can be exploited to execute arbitrary code loaded from an LDAP server
CVSS 3.x Score & Vector	10.0 CRITICAL (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
Components affected	log4j-core
Versions affected	[2.0-beta9, 2.3.1) u [2.4, 2.12.2) u [2.13.0, 2.15.0)
Versions fixed	2.3.1 (for Java 6), 2.12.2 (for Java 7), and 2.15.0 (for Java 8 and later)

Description

In Log4j, the JNDI features used in configurations, log messages, and parameters do not protect against attacker-controlled LDAP. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers.

Note that only the log4j-core JAR file is impacted by this vulnerability. Applications using only the log4j-api JAR file with not impacted by this vulnerability.

Mitigation

Log4j 1 mitigation

WARNING

Log4j 1 has reached End of Life in 2015, and is no longer supported. Vulnerabilities reported after August 2015 and will not be fixed. Users should upgrade to Log4j 2 to obtain security fixes.

Log4j 1 does not have Lookups, so the risk is lower. Applications using Log4j 1 are only vulnerable to this attack when they use CVE (CVE-2021-4104) has been filed for this vulnerability. To mitigate, audit your logging configuration to ensure it has no JMSA configurations without JMSAppender are not impacted by this vulnerability.

Log4j 2 mitigation

Upgrade to Log4j 2.3.1 (for Java 6), 2.12.2 (for Java 7), or 2.15.0 (for Java 8 and later).

Credits

This issue was discovered by Chen Zhaojun of Alibaba Cloud Security Team.

2. CVD – Coordinated Vulnerability Disclosure

Koordinierte Offenlegung mit mehreren Akteuren zur Minimierung von Risiken.

Akteure:

- Entdecker: Chen Zhaojun (Alibaba)
- Koordination: Apache Software Foundation, CISA, CERTs weltweit

Ablauf:

- 24.11.2021: Meldung an Apache
- 09.12.2021: Erste Hinweise auf GitHub
- 10.12.2021: Veröffentlichung CVE-2021-44228
- 17.12.2021: Veröffentlichung von Log4j 2.17.0

Reaktion: CISA veröffentlichte Emergency Directive 22-02

Quelle: CISA Advisory AA21-356A

ED 22-02: Mitigate Apache Log4j Vulnerability

Status Report Template (Version 1.0)



Please ensure that this document, if populated, is only shared with those with need to know and is not further disseminated outside the Department of Homeland Security (DHS)/Cybersecurity and Infrastructure Security Agency (CISA) and/or the federal agency populating the report (the "reporting agency"). DHS/CISA understands that the reporting agency may distribute this report to its contractors or other support personnel who need to know the information to protect the reporting agency or prevent further harm to the reporting agency.

Agency Name:

Point of Contact (POC) Name:

POC Email Address:

POC Phone Number:

Please select from the list

Instructions:

Submit your responses to CyberDirectives@cisa.dhs.gov by 5pm on December 28, 2021.

Please reach out to CyberDirectives@cisa.dhs.gov with any questions, comments, or concerns as you complete this form.

Please provide the following information:

1) Has your agency, to the best of its ability, enumerated all solution stacks accepting user data input from the internet?	
2) Has your agency evaluated all software assets in identified stacks against CISA's managed GitHub repository (https://github.com/cisagov/log4j-affected-db) to determine whether Log4j is present in those assets and if so, whether those assets are affected by the vulnerability?	
3) Has your agency identified any software assets as affected by the Log4j vulnerability?	
If your answer to number 1 or 2 is "Not Yet Complete," please provide the estimated completion date (ECD) here: <And/Or> If your answer to number 3 is "Yes," please provide details in the inventory tab.	
4) Additional comments, e.g. constraints impacting your agency's ability to enumerate, evaluated, update, or support needs, observations, challenges, and technical issues.	

3. CVE – Common Vulnerabilities and Exposures

Eindeutige Identifikation der Schwachstelle.

- **CVE-ID:** CVE-2021-44228
- **Beschreibung:** RCE durch JNDI Lookup in Log4j
- **CVSS-Score:** 10.0 (kritisch)
- **Veröffentlicht:** 10. Dezember 2021
- **Zuständige CNA:** Apache Software Foundation

Quelle: NVD CVE-Eintrag

CVE-2021-44228 Detail

Description

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 10.0 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

ADP: CISA-ADP

Base Score: 10.0 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

4. CVSS – Common Vulnerability Scoring System

Bewertung der Kritikalität der Schwachstelle.

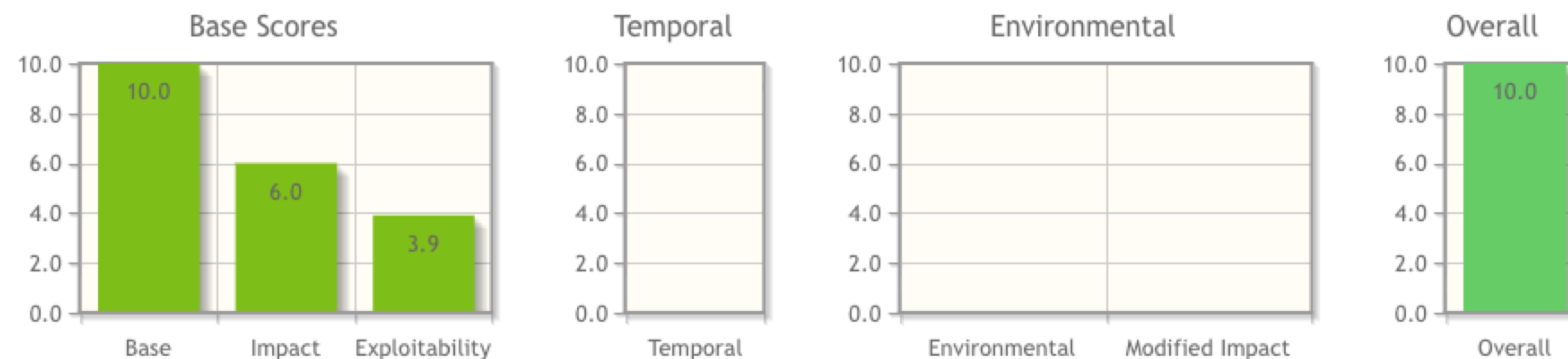
CVSS v3.1 Vektor:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Bedeutung:

- **AV:N** – Angreifbar über das Netzwerk
- **AC:L** – Geringe Komplexität
- **PR:N** – Keine Privilegien nötig
- **UI:N** – Keine Benutzerinteraktion
- **S:C** – Auswirkungen auf mehrere Komponenten
- **C/I/A:H** – Hoher Schaden in Vertraulichkeit, Integrität, Verfügbarkeit

Quelle: NVD CVSS-Bewertung



CVSS Base Score: 10.0
Impact Subscore: 6.0
Exploitability Subscore: 3.9
CVSS Temporal Score: NA
CVSS Environmental Score: NA
Modified Impact Subscore: NA
Overall CVSS Score: 10.0

[Show Equations](#)

5. VDA – Vulnerability Disclosure Advisory

Herstellerwarnungen mit Handlungsempfehlungen.

Beispiel: Cisco Advisory

Inhalt:

- Liste betroffener Produkte
- Patch-Informationen und Hotfixes
- Snort-Regeln zur Erkennung von Angriffen

Datum: 10. Dezember 2021 (erste Version), laufend aktualisiert

Vulnerabilities in Apache Log4j Library Affecting Cisco Products



Advisory ID:	cisco-sa-apache-log4j-qRuKNEbd	CVE-2021-44228	Download CVRF
First Published:	2021 December 10 18:45 GMT	CVE-2021-45046	Download PDF
Last Updated:	2021 December 22 22:58 GMT	CVE-2021-45105	Email
Version 1.27:	Interim	CWE-20	
Workarounds:	No workarounds available	CWE-502	
CVSS Score:	Base 10.0  Click Icon to Copy Verbose Score CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/E:X/RL:X/RC:X	CWE-674	

Summary

Critical Vulnerabilities in Apache Log4j Java Logging Library

On December 9, 2021, the following critical vulnerability in the Apache Log4j Java logging library affecting all Log4j2 versions earlier than 2.15.0 was disclosed:

CVE-2021-44228: Apache Log4j2 JNDI features do not protect against attacker controlled LDAP and other JNDI related endpoints

On December 14, 2021, the following critical vulnerability, which affects certain Apache Log4j use cases in versions 2.15.0 and earlier, was disclosed:

CVE-2021-45046: Apache Log4j2 Thread Context Message Pattern and Context Lookup Pattern vulnerable to a denial of service attack

On December 18, 2021, a vulnerability in the Apache Log4j component affecting versions 2.16 and earlier was disclosed:

6. VDP – Vulnerability Disclosure Policy

Richtlinie zur Meldung von Schwachstellen durch externe Forscher.

Beispiele:

- [CISA VDP Template](#)
- [VDP Post CH](#)

Inhalte:

- Was ist erlaubt (z. B. kein DoS, kein Social Engineering)
- Wie wird gemeldet (z. B. Webformular, E-Mail)
- Schutz der Forscher bei gutem Verhalten („Safe Harbor“)

Ziel: Förderung von verantwortungsvoller Offenlegung



This template is intended to assist your agency in the creation of a vulnerability disclosure policy (VDP) that aligns with [Binding Operational Directive \(BOD\) 20-01](#).

- *Instructions for how to use the template and some example text are provided throughout the document in red and italic text. These should be changed and removed from your published policy.*
- *You are encouraged to modify the template to suit your needs, but your policy must address all actions required by the Directive. It is **strongly recommended** that you use the template's language for the Authorization section.*
- *CISA recommends that you review the [implementation guidance](#) maintained in support of this directive, particularly the section [Consider prior art](#).*
- *Your policy must be published as a public web page in plain text or HTML at the ["/vulnerability-disclosure-policy"](#) path of your agency's primary .gov website.*

The primary sources for this template were the General Services Administration's [Technology Transformation Services' VDP](#), the [Department of Defense's VDP](#), and a VDP template from a 2016 working group of the [National Telecommunications and Information Administration](#). It has been written to align with the Department of Justice's [Framework for a Vulnerability Disclosure Program for Online Systems](#).

Vulnerability Disclosure Policy

Agency Name

Month Day, Year

Introduction

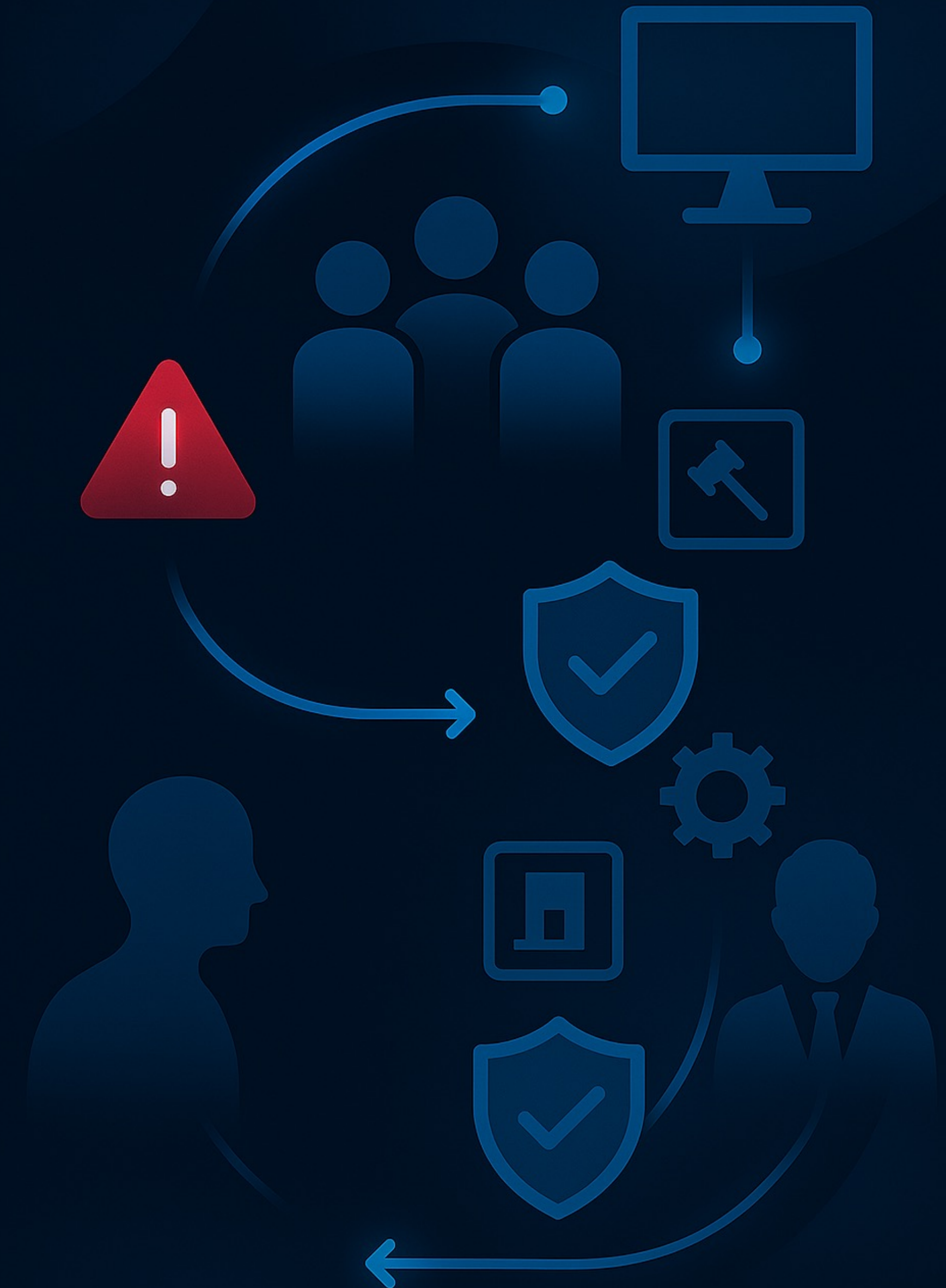
An introductory section that provides background information about your organization and your VDP. It should take a committed, concerned, and receptive tone.

Agency Name is committed to ensuring the security of the American public by protecting their information. This policy is intended to give security researchers clear guidelines for conducting vulnerability discovery activities and to convey our preferences in how to submit discovered vulnerabilities to us.

Gruppenarbeit

Zeit: 20 min; anschliessend
präsentieren im Plenum auf
einem Slide in ca. 3 min.

Information Technology
October 22, 2025



Gruppenarbeit

Miro Board: https://miro.com/app/board/uXjVJ3fZwog=/?share_link_id=808909312194

Zeit: 20 min; anschliessend Präsentation im Plenum auf einem Slide in ca. 3 min.

→ Slide im Miro Board verwenden

Team	Thema
Team Ägerisee	Recherchieren Sie eine weitere bekannte Schwachstelle aus der letzten Zeit (nicht Solarwinds, nicht Log4Shell)
Team Zugersee	Welche Kosten verursachen Schwachstellen ungefähr jährlich weltweit?
Team Baldeggersee	Wieviel geben Firmen wie Google, Apple, Microsoft, ... ungefähr jährlich aus, um über Bug-Bounty-Programme Schwachstellen zu finden?
Team Vierwaldstättersee	Wieviel würde es ungefähr kosten, alle bekannten Schwachstellen eines Jahres (bspw. 2024) über Bug-Bounties einzukaufen?
Team Hallwilersee	Wie finde ich Schwachstellen in meiner IT und wie behalte ich den Überblick?
Team Rotsee	Wie hängen Schwachstellen mit ISO27001, CRA und NIS-2 zusammen?
Team Sempachersee	Wo finde ich gute Beispiele zum Thema Kommunikation von Schwachstellen?

Team Ägerisee

1. CVE-2024-23897 – Jenkins CLI

- **CVSS:** 9.8
- **Beschreibung:** Fehlerhafte Verarbeitung von Befehlen im Jenkins Command Line Interface ermöglicht Remote Code Execution.
- **Relevanz:** Weit verbreitetes CI/CD-Tool, oft in DevOps-Umgebungen eingesetzt.

2. CVE-2024-0204 – Fortra GoAnywhere MFT

- **CVSS:** 9.8
- **Beschreibung:** Authentifizierungsumgehung in Managed File Transfer-Systemen.
- **Relevanz:** Besonders gefährlich für Unternehmen mit sensiblen Datenübertragungen.

3. CVE-2024-21887 – Ivanti Connect Secure

- **CVSS:** 9.1
- **Beschreibung:** Command Injection über Web-Interface.
- **Relevanz:** VPN-Systeme sind oft direkt mit dem Internet verbunden – hohes Risiko.

4. SUN:DOWN – Schwachstellen in Solarinfrastruktur

- **Betroffene Hersteller:** Sungrow, Growatt, SMA
- **Anzahl Schwachstellen:** 46 neue, davon ein Drittel mit CVSS 9.8–10
- **Beschreibung:** Unsichere Authentifizierung, hartcodierte Zugangsdaten, OTA-Update-Schwächen
- **Relevanz:** Kritische Infrastruktur, z. B. Energieversorgung und Kliniken betroffen

Team Zugersee

Die weltweiten Kosten durch IT-Sicherheitsschwachstellen und Cyberangriffe sind in den letzten Jahren dramatisch gestiegen. Hier sind die wichtigsten aktuellen Zahlen und Erkenntnisse:

Globale Kosten durch Cyberangriffe und Sicherheitslücken

- **2023: ca. 8 Billionen USD**
- **2024: ca. 9,5 Billionen USD**
- **2025 (Prognose): ca. 10,5 Billionen USD**

Diese Zahlen umfassen direkte Schäden durch Datenschutzverletzungen, Systemausfälle, Erpressung (z. B. Ransomware), sowie indirekte Kosten wie Reputationsverlust und Betriebsunterbrechungen.

Durchschnittliche Kosten pro Sicherheitsvorfall (laut IBM und dem Ponemon Institute)

- **2024: ca. 4,88 Mio. USD** pro Vorfall
- **2025: leicht gesunken auf 4,4 Mio. USD**, dank schnellerer Reaktion und KI-gestützter Sicherheitsmassnahmen

Branchen und Regionen mit höchsten Schäden

- **Gesundheitswesen:** Durchschnittlich **10,93 Mio. USD** pro Vorfall
- **USA:** Höchste durchschnittliche Kosten weltweit mit **9,48 Mio. USD** pro Vorfall (CH ca. **4.476 USD**)

Team Baldeggersee

1. Microsoft

- **2024: 16,6 Millionen USD** an Sicherheitsforscher ausgezahlt
- **Anzahl belohnter Forscher:** 343 aus 55 Ländern
- **Höchste Einzelprämie:** 200.000 USD
- **Programme:** Azure, Edge, M365, Dynamics 365, Windows, Xbox, KI, Identity, Secure Boot

2. Google

- **2023: 10 Millionen USD** ausgezahlt
- **2022:** Rekordjahr mit **12 Millionen USD**
- **Gesamt seit 2010:** über **59 Millionen USD**
- **Höchste Einzelprämie 2023:** 113.337 USD
- **Programme:** Android, Chrome, Wear OS, AI-Produkte (z. B. Gemini), Open Source

3. Apple

- **Maximale Einzelprämie:** bis zu **2 Millionen USD** (z. B. für Lockdown-Mode-Bypass)
- **Typische Prämienbereiche:**
 - Zero-Click Exploits: bis zu **1 Mio. USD**
 - Remote Code Execution: **10.000–50.000 USD**
 - iCloud-Datenübernahme: **10.000–100.000 USD**
- **Gesamtausgaben pro Jahr:** nicht öffentlich, aber Schätzungen gehen von **mehreren Millionen USD** aus

Team Vierwaldstättersee

1. Grundlage: CVE-Daten 2024

- **Anzahl veröffentlichter CVEs:** ca. **40.009**
- **Durchschnittlicher CVSS-Score:** 6.67 (mittlere bis hohe Kritikalität)
- **Anteil kritischer Schwachstellen (CVSS ≥ 9):** ca. **15–20 %** → ca. **6.000–8.000 CVEs**

2. Durchschnittliche Bug-Bounty-Prämien

- **Allgemeiner Durchschnitt pro CVE:** ca. **\$1.000–\$5.000**
- **Für kritische Schwachstellen:** \$10.000–\$100.000 (z. B. RCE, Zero-Day)
- **Höchste Einzelprämien:** bis zu **\$2 Mio.** (Apple Lockdown Mode Bypass)

3. Grobe Kostenschätzung

- Wenn man **alle CVEs eines Jahres „einkaufen“ wollte**, lägen die **realistischen Kosten zwischen 80 Mio. und 300 Mio. USD**, je nach Kritikalität und Prämienhöhe.
- Der **Bug-Bounty-Markt als Ganzes** bewegt sich jedoch in einem **deutlich höheren Bereich**, da nicht jede Schwachstelle über ein Bounty gemeldet wird und Plattformen zusätzliche Services bieten.

Team Hallwilersee

Schwachstellen finden

Automatisierte Scans

- **Tools:** Nessus, OpenVAS, Qualys, Rapid7
- **Funktion:** Scannen Netzwerke, Systeme und Anwendungen auf bekannte CVEs
- **Vorteil:** Regelmäßige, automatisierte Erkennung

Penetrationstests

- **Manuell oder automatisiert**
- **Ziel:** Simulation echter Angriffe zur Identifikation komplexer Schwachstellen
- **Tools:** Metasploit, Burp Suite, Kali Linux

Code-Analyse & SAST/DAST

- **SAST (Static Application Security Testing):** z. B. SonarQube, Checkmarx
- **DAST (Dynamic Application Security Testing):** z. B. OWASP ZAP

Bug-Bounty & Responsible Disclosure

- **Plattformen:** HackerOne, Bugcrowd, Intigriti
- **Vorteil:** Externe Experten finden Schwachstellen gegen Prämien

Überblick behalten

Vulnerability Management Tools

- **Beispiele:** Tenable.io, Qualys VMDR, Rapid7 InsightVM
- **Funktion:** Inventarisieren, bewerten, priorisieren und dokumentieren von Schwachstellen

Asset Management

- **Tools:** Lansweeper, GLPI, ServiceNow
- **Ziel:** Überblick über alle Systeme, Softwareversionen und Konfigurationen

Dashboards & Reports

- **Zentrale Übersicht:** z. B. mit SIEM-Systemen wie Splunk, Microsoft Sentinel
- **Automatisierte Alerts:** bei neuen CVEs oder kritischen Schwachstellen

Patch-Management

- **Tools:** WSUS, Ivanti, ManageEngine
- **Ziel:** Regelmäßige Updates und Patches zur Behebung erkannter Schwachstellen

Team Rotsee

Element	ISO/IEC 27001	CRA	NIS-2
Schwachstellen-Scan	empfohlen	verpflichtend für Hersteller	verpflichtend für Betreiber
CVE/CVSS-Nutzung	empfohlen	empfohlen	empfohlen
CVD/VDP-Prozesse	optional	verpflichtend	empfohlen
Meldepflicht	keine direkte Pflicht	an ENISA	an nationale Behörden
Auditierbarkeit	hoch	sehr hoch	sehr hoch

Team Sempachersee

1. **Security Advisories von Herstellern**

- Beispiel: Microsoft, Cisco, SAP, Fortinet, etc.
- Enthalten technische Details, CVE-Nummern, Patches und Empfehlungen.
- Gut geeignet für die Analyse von Sprache, Struktur und Transparenz.

2. **CERT-Meldungen**

- Beispiel: CERT-Bund (BSI), US-CERT, GovCERT
- Oft neutral formuliert, mit Fokus auf Auswirkungen und Maßnahmen.
- Ideal für Vergleiche zwischen staatlicher und unternehmensinterner Kommunikation.

3. **Bug-Bounty-Plattformen**

- Beispiel: HackerOne, Bugcrowd
- Enthalten echte Reports von Sicherheitsforschern und die Reaktion der Unternehmen.
- Besonders spannend für die Analyse von Disclosure-Prozessen.

4. **CVE-Einträge**

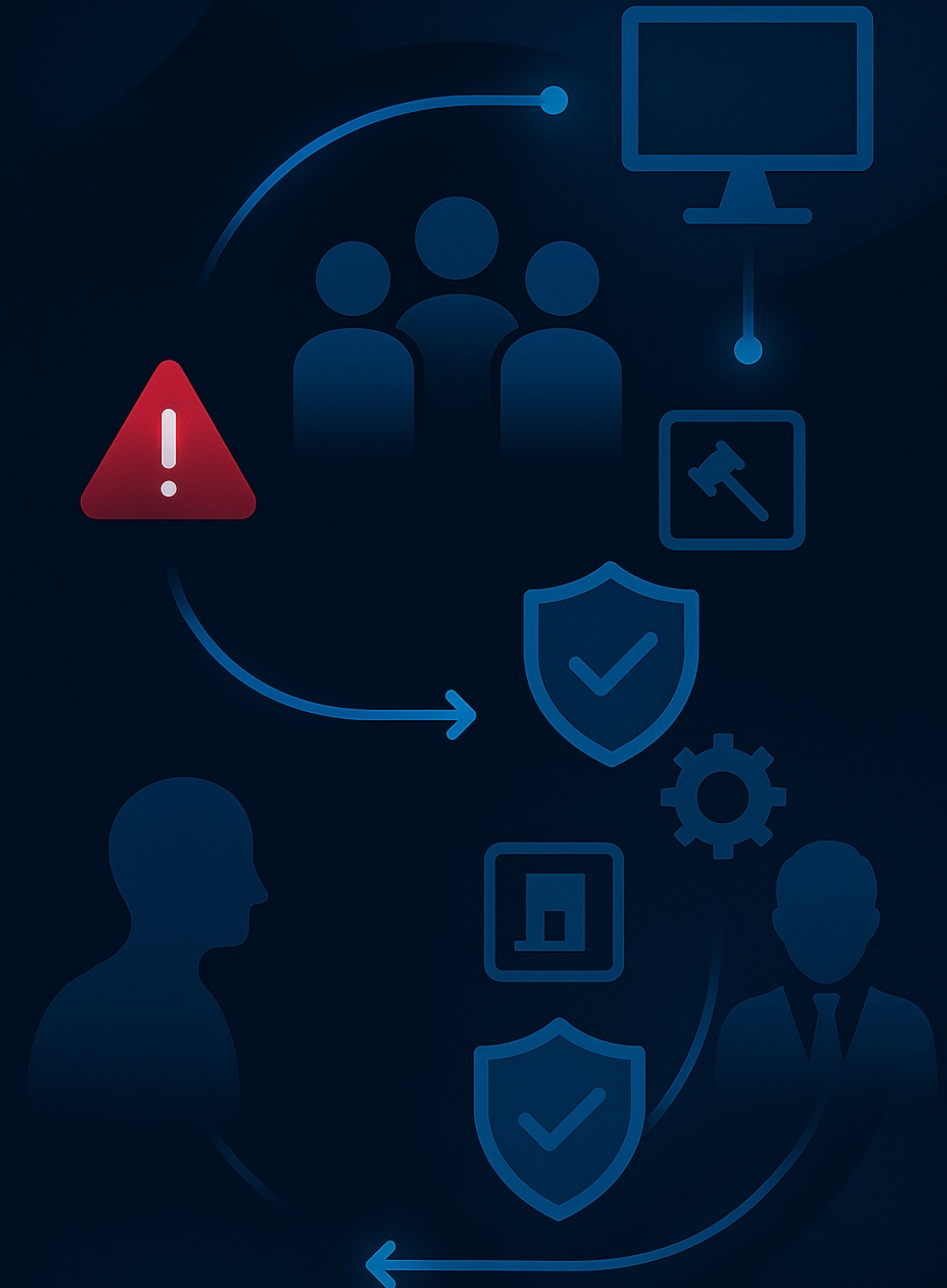
- Beispiel: CVE Details, NVD (National Vulnerability Database)
- Technisch, aber oft mit Links zu Advisories und Patches.
- Gut für die Einordnung und Vergleichbarkeit von Schwachstellen.

Akteure und Kommunikation

Information Technology

October 22, 2025

FH Zentralschweiz



Akteure und ihre Rollen im Schwachstellenprozess

Akteur	Rolle / Verantwortung	Bezug zu Prozessen
Finder (Researcher, Hacker, Bug-Bounty)	Entdeckt Schwachstellen, meldet sie	CVD, VDR, CVE
Hersteller / Vendor	Analysiert, behebt und veröffentlicht Schwachstellen	CVD, VDA, VDP
CNA (CVE Numbering Authority)	Vergibt CVE-IDs, prüft Einträge	CVE
MITRE Corporation	Koordiniert das CVE-System weltweit	CVE
FIRST.org	Entwickelt und pflegt das CVSS-System	CVSS
CERTs (z. B. CERT/CC, BSI CERT-Bund)	Koordinieren Offenlegung, unterstützen bei CVD	CVD, VDA
Behörden (z. B. ENISA, BSI, NIST)	Regulieren, überwachen, veröffentlichen Richtlinien	CVD, VDP, CRA, NIS-2
Bug-Bounty-Plattformen (z. B. HackerOne, Bugcrowd)	Vermitteln zwischen Finder und Hersteller	VDR, VDP
NVD (National Vulnerability Database)	Ergänzt CVE mit CVSS, CPE, Exploitability etc.	CVE, CVSS
Security-Teams / SOC / IT-Abteilungen	Bewerten, patchen, dokumentieren Schwachstellen	CVSS, VDR, VDA
Compliance & Legal Teams	Prüfen rechtliche Anforderungen, koordinieren Disclosure	VDP, CRA, NIS-2

Folgendes Szenario:

Sie entdecken eine kritische Schwachstelle in der Webanwendung 'EduPortal', die an vielen Hochschulen eingesetzt wird. Die Schwachstelle erlaubt Remote Code Execution (RCE) ohne Authentifizierung.

Was tun Sie in der Rolle des **Finders**?

Was tun Sie in der Rolle des **Entwicklers** von "EduPortal"?

Was tun Sie in der Rolle des **Herstellers** der Softwarelösung "EduPortal"?

Was tun Sie in der Rolle des **Anwenders** von "EduPortal"?

...

...

Veröffentlichung
Geheim halten?

Nur dem Hersteller
mitteilen?

An den Meistbietenden
verkaufen?

Öffentlich gemäss CVD
mitteilen?

Security.txt

- RFC (Request for comments) 9116 : Soll die Kommunikation von sicherheitsrelevanten Informationen betreffend einer Webseite an dessen Betreiber vereinfachen, siehe <https://www.rfc-editor.org/rfc/rfc9116>
- Dies erfolgt über die Standardisierung der Angabe von relevanten Kontaktinformationen:
 - Contact: E-Mail-Adresse oder Formular zur Meldung von Schwachstellen
 - Encryption: Link zu einem öffentlichen PGP-Schlüssel
 - Acknowledgements: Seite mit Anerkennung für Finder
 - Policy: Link zur vollständigen VDP
 - Hiring: Hinweis auf Jobangebote im Security-Bereich
 - Preferred-Languages: z. B. en, de
- Seit April 2022 von der Internet Engineering Task Force (IETF) angenommen: Es wird eine Datei namens security.txt definiert, die ähnlich der robots.txt an einem standardisierten Ort hinterlegt wird und von Menschen wie Maschinen lesbar sein soll
- Beispiele:
 - <https://www.google.com/.well-known/security.txt>
 - <https://www.sbb.ch/.well-known/security.txt>
 - <https://www.post.ch/.well-known/security.txt>
 - <https://threema.ch/.well-known/security.txt>

```
# To report security vulnerabilities, please find SBB's public Bug Bounty program at Intigriti.
Contact: https://app.intigriti.com/programs/sbb/sbbglobal
# In exceptional cases only
Contact: mailto:securityissues@sbb.ch

# Open positions
Hiring: https://company.sbb.ch/en/jobs-careers/jobs/vacancies.html

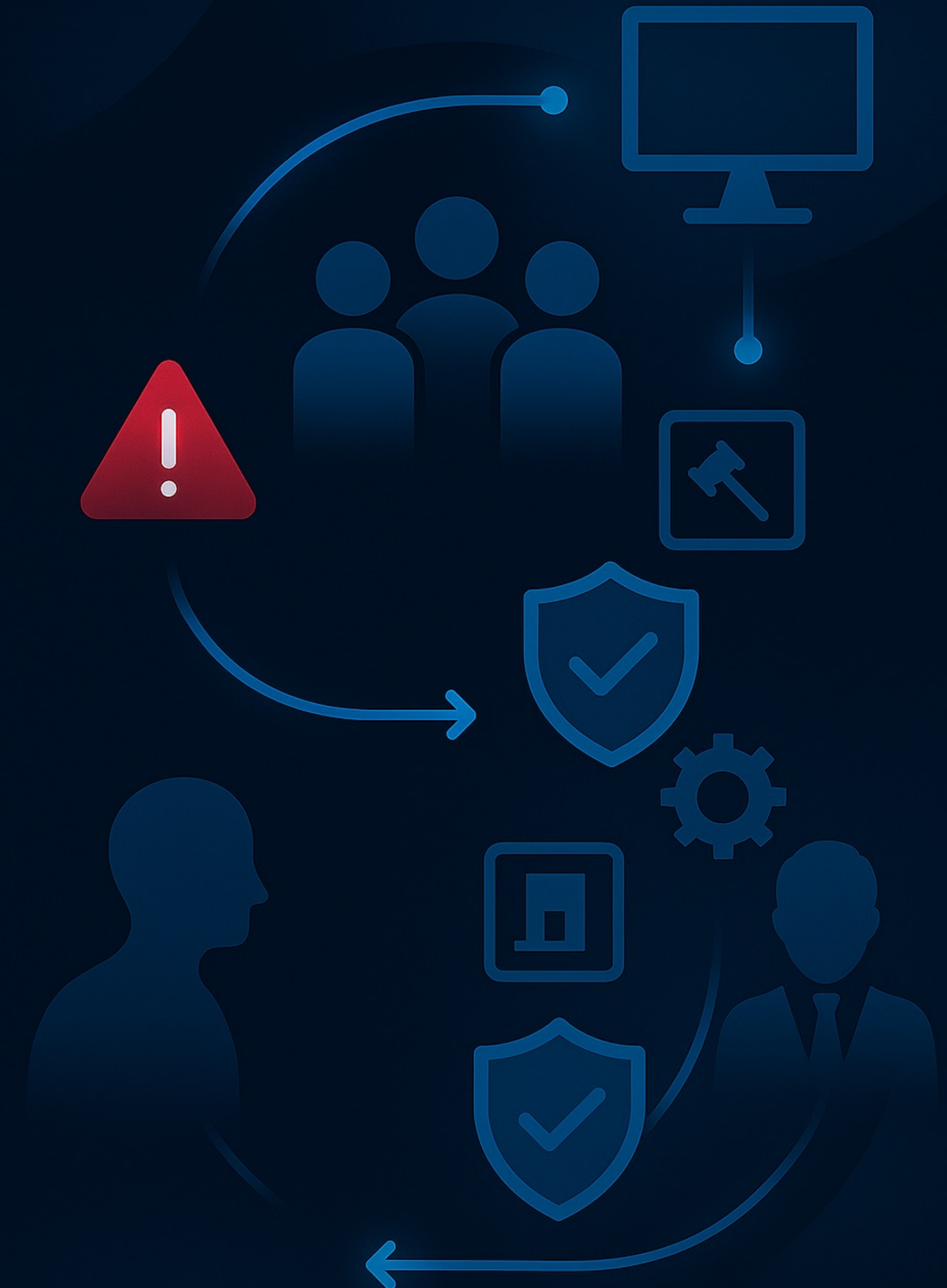
Canonical: https://www.sbb.ch/.well-known/security.txt
Expires: 2025-12-31T23:59:00.000Z
Preferred-Languages: en, de
```

Checkliste: Kommunikation im Schwachstellenmanagement

Thema	Standard / Leitlinie	Was ist zu tun?	Wer ist zuständig?
Schwachstelle melden	ISO/IEC 29147, VDP	VDP veröffentlichen (z. B. security@domain.tld, security.txt)	Organisation
Schwachstelle dokumentieren	VDR	Technische Details erfassen, Auswirkungen analysieren	Finder, Hersteller
Koordinierte Offenlegung	ISO/IEC 29147, BSI CVD-Leitlinie, FIRST Guidelines	Zeitplan abstimmen, Kommunikation mit Finder und ggf. CERT	Hersteller, CERT
CVE-ID beantragen	CVE via CNA (z. B. MITRE)	CVE-Formular ausfüllen, technische Beschreibung bereitstellen	Hersteller, CERT, CNA
Schwachstelle bewerten	CVSS via FIRST	CVSS-Metriken anwenden, Score berechnen	Security-Team, Hersteller
Advisory veröffentlichen	VDA	CVE, CVSS, Fixes, Workarounds kommunizieren	Hersteller, CERT
Interne Behandlung	ISO/IEC 30111	Schwachstelle analysieren, priorisieren, patchen	IT-Security-Team
Mehrparteien-Koordination	FIRST Guidelines	Koordinator benennen, Disclosure synchronisieren	CERT, Hersteller

Leistungsnachweis und Coaching

Information Technology
October 22, 2025



Leistungsnachweis

Gegeben ist folgendes Szenario:

Ein externer Sicherheitsforscher entdeckt eine kritische Schwachstelle in Ihrer Webanwendung 'EduPortal', die an vielen Hochschulen eingesetzt wird. Die Schwachstelle erlaubt Remote Code Execution (RCE) ohne Authentifizierung.

Aufgabe:

1. Spielen Sie im Team den Schwachstellenprozess durch. Verteilen Sie die Rollen und beschreiben Sie ihre Aufgaben:
- Finder (Researcher)
 - Hersteller (Vendor)
 - CERT (Koordinator)
 - CNA (z. B. MITRE)
 - Security-Team (CVSS-Bewertung)
2. Erstellen Sie einen passenden „Advisory“ (VDA)

Umfang: Zusammen ca. 1 Seite, passend zum Szenario

Bewertungskriterien:

Kriterien "Vulnerability Disclosure Advisory"	mögliche Punkte
Sinnvolle Beschreibung der Vulnerability, passend zum Unternehmen	3
Advisory enthält alle nötige Informationen	3
Aussagekräftige Sätze, Verständlichkeit, Nachvollziehbarkeit	3
Überzeugend, auf Zielpublikum zugeschnitten	2
Gesamtbeurteilung (Summe Punkte)	11.00
Note für Gesamtpunktzahl	6

Nächste Schritte

Datum für optionales Coaching:	Dienstag 28.10.25 via Zoom oder onsite Raum: I.S1A_222
Anmeldung für Coaching:	Bis 26.10.25 Coaching-Wünsche und Fragen per E-Mail an mich
Zeitplan:	15:30 - 15:45 Team Ägerisee 15:45 – 16:00 Team Zugersee 16:00 – 16:15 Team Baldeggersee 16:15 – 16:30 Team Vierwaldstättersee 16:30 – 16:45 Team Hallwilersee 16:45 – 17:00 Team Rotsee 17:00 – 17:15 Team Sempachersee
Abgabe Leistungsnachweis:	4. November 25, 20h00 min via Ilias

Danke!

School of Computer Science and Information Technology

Degree Programs

Frank Heinzmann

Senior Lecturer

Phone direct

frank.heinzmann@hslu.ch